

Developer Guide: System-to-System authentication / clinical applications

The purpose of this guide is to provide guidance to frequently asked questions for Developers.

Sample http request headers

```
1 x-api-key: xdXok*****
2 authorization: Bearer eyJ*****
3 x-correlation-id: 02ee5aeb-ef35-1111-848a-111111111111
4 request-context: ....
```

Header overview

Header	Mandatory	Description	Example value
x-api-key	no	[Deprecated] For System to system use cases, x-api-key is depreciated for system-to-system interactions.	
authorization	✓	Required for coarse and fine-grained authorisation of an API request. It's a JWT issued by our IDP which contains a number of claims to authorise your request at the gateway.	
x-correlation-id	optional	The correlation id (UUID) identifies a specific request. It is recommended to use this header for tracing purposes.	7b12523e-1009-423f-95b8-60055d7cd9e8
request-context	✓	Mandatory metadata for the request as specified in schemas/Request-Context.json at main · tewhatuora/schemas (github.com) , encoded as JWT or base64 string README	

Detailed header descriptions

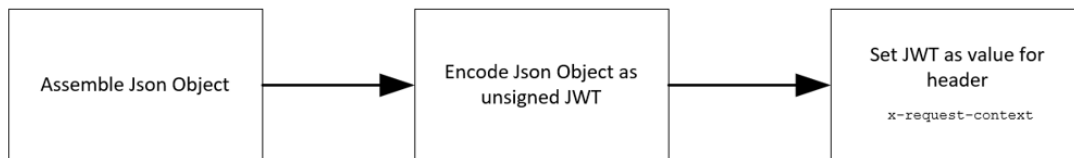
request-context

Relevance

The request context header transports information relevant for audit and backend systems. In contrary to most other headers which are mainly of *technical* and *security* relevance, this header, providing information about in which context the information is accessed (who, why, where, etc.), is of **legal** relevance. Filling this header correctly is therefore, as described in the onboarding documents and contracts, of high importance.

Format

The value of the header is an unsigned JWT OR simply a base64 string. If using a JWT, the payload is a serialized json object matching the schema defined in [schemas/Request-Context.json at main · tewhatuora/schemas \(github.com\)](https://github.com/tewhatuora/schemas/blob/main/Request-Context.json). If using plain base64 string, then only serialize the json object, and omit the header and signatures as required by JWT.



Steps to generate the value for the `request-context` header

📝 An “unsigned” JWT is created by setting the algorithm to `none` and omitting the signature part. Example:

```
{
  "alg": "None",
  "typ": "JWT"
}
```

It is questionable though if we should go down this route, as some JWT generation libraries might not even provide the option to generate an unsigned JWT.

Three options at the moment:

1. Use Base64 encoded serialized json instead of JWT
2. Accept signed JWTs and do not validate the signature / ignore validation errors
3. Require signed JWTs and exchange public keys with all parties (a lot of effort)
4. Continue with unsigned JWTs

Field	Example Value	Description / Notes
userIdentifier	2295893	Unique user identifier of the person, usually practitioner or health workforce team member, triggering the request, as user in the client system. Every request is triggered by a person, who is a user of the client system. Every client system maintains a directory of their users, including a unique identifier and other features. The

		personal identifier maintained about a person in the client system and transmitted via this field is expected to be an alphanumeric string and must not be the name or email address of the person. This value is mandatory and must be correct and accurate, due to legal requirements.
userRole	PROV	FHIR role the user assumes for the specific request, as specified in Valueset-participation-role-type - FHIR v4.3.0. This value is mandatory and must be correct, due to legal requirements.
secondaryIdentifier.use	official	Static value <code>official</code> Mandatory.
secondaryIdentifier.system	https://standards.digital.health.nz/ns/hpi-person-id	Registration body namespace. If the person, usually practitioner or health workforce team member, triggering the request is registered with a New Zealand health body such as the Medical Council of New Zealand, the Nursing Council of New Zealand, they will have a registration identifier within that body. The list of valid registration identifier namespaces is available here: standards.digital.health.nz. This value is mandatory and must be correct and accurate, due to legal requirements. If the person triggering the request is not registered with any New Zealand health body on the list provided, the value must remain empty (empty string).
secondaryIdentifier.value	00AAA A	Registration Id of the practitioner or health workforce team member with a New Zealand health body. If the person, usually practitioner or health workforce team member, triggering the request is registered with a New Zealand health body such as the Medical Council of New Zealand, the Nursing Council of New Zealand, they will have a registration identifier within that body. The list of valid registration identifier namespaces is available here: standards.digital.health.nz. In many cases the value will be the "CPN". This value is mandatory and must be correct and accurate, due to legal requirements. If the person triggering the request is not registered with any New Zealand health body on the list provided, the value must remain empty (empty string).
purposeOfUse	["TRE AT"]	Purpose of the request as specified in HL7.TERMINOLOGY\PurposeOfUse - FHIR v4.0.1. The field contains a list of one or multiple <code>purposeOfUse</code> values. At least one value must be given. Technically, multiple values can be added according to the JSON specification, such as <code>["<pou1>", "<pou2>", "<pou3>"]</code>. For acceptable and permitted values,

		please refer to the onboarding documents and contractual documentation, as some values may be technically accepted, but not legally acceptable. The value is mandatory, must be correct and accurate, and the list must contain at least one purpose of use, due to legal audit requirements.
userFullName	Dr. Jane Doe	Full name of the person, usually practitioner or health workforce team member, causing the request. The value is mandatory and must be correct and accurate, due to legal audit requirements.
orgIdentifier	GAA000-Z	Organisation of the person, usually practitioner or health workforce team member, causing the request. The value must be a valid HPI ORG ID as specified in HPI Overview – Health New Zealand Te Whatu Ora. This value is mandatory and must be correct and accurate, due to legal audit requirements.
facilityIdentifier	FAA000-Z	Facility of the person, usually practitioner or health workforce team member, causing the request. The value must be a valid HPI FAC ID as specified in HPI Overview – Health New Zealand Te Whatu Ora. This value is mandatory and must be correct and accurate, due to legal audit requirements.

Example Request-context JSON

```

1  {
2    "jti": "e825038c-0a75-422b-9ce1-6e4684c9dff8",
3    "userIdentifier": "DrJane",
4    "userRole": "PROV",
5    "secondaryIdentifier": {
6      "use": "official",
7      "system": "https://standards.digital.health.nz/ns/hpi-person-id",
8      "value": "ZZ1234"
9    },
10   "purposeOfUse": [
11     "UNKNOWN"
12   ],
13   "userFullName": "Dr. Jane Doe",
14   "orgIdentifier": "GAA001-1",
15   "facilityIdentifier": "FAA001-1"
16 }

```

Example Postman Request

GET
https://api.uat.nhi.digital.health.nz/s2s/fhir/nhi/v1/Patient/ZAA0270

Params
Authorization
Headers (6)
Body
Scripts
Settings

☐	x-api-key	{{API_Key}}
☐	userid	{{UserId}}
☐	client_id	{{ClientId}}
☐	client_secret	{{ClientSecret}}
☒	request-context	eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJqdGkiOiJlODI1MDM4Yy0wYTc1L...
☐		
	Key	Value

OAuth Details

We use OAuth2.0 Client Credentials flow to Authorise API calls. The flow is designed for system to system interactions which fits this use case. This is the same flow that the HIP services and many other Key details to know:

- Token Life is 60min, it's recommended to implement a token cache and refresh project for performance reasons.
- Please use below connection details and credentials. Note that we only support sending credentials in the POST body.
- OAuth2 Token URL: PROD <https://auth.digital.health.nz/realms/master/protocol/openid-connect/token>
- PreProd <https://ppd.auth.digital.health.nz/realms/master/protocol/openid-connect/token>
- You must explicitly request the OAuth Scopes that you are wanting in your token. Multiple scopes are space-separated e.g. `system/Patient.s system/Location.s system/Practitioner.s`

Compliance testing:

Compliance testing is a software testing that checks whether an API Consumer's system, product, or software application, adheres to specified standards, protocols, or regulations. Compliance testing helps to validate that an API Consumer application aligns with a predetermined set of rules and guidelines imposed by API Provider, enhancing overall quality, eligibility, reliability, and interoperability.

Access to Mock+

Key API Policies for Clients to be aware of:

- Correlation ID - Correlation ID is an identifier that will follow the API request end-to-end. It's required to be a GUID. If you do not provide a valid GUID (including not supplying one at all), the response headers will contain a Correlations ID provisioned by the server.
- Rate Limiting - Gold, silver, bronze tiers are allocated which have a particular quota. Quotas vary depending on the API service, but generally have a burst limit for a second, and a daily limit. If you reach the quota limit, you will receive a `429 - Too many requests` error and will need to handle it gracefully in your application (there is generally a compliance test for you to demonstrate this)
- Spike Control - Spike control is in place to protect the backend service from traffic spike. Generally, this will be transparent for a API client's perspective. When a spike of traffic is identified over the backend system threshold, incoming requests will be queued and throttled leading to increased response time. If the queue depth exceeds a

further threshold, the API client will experience a `429 - Too many requests` error, even if the allowable quota hasn't been met.

- GeoFencing - GEO Restriction rules prevent access from clients with IPs located in countries other than those listed below.
 - New Zealand
 - Australia
 - Canada
 - Cook Islands